

Cadre de réponse aux incidents

9567-0048 Québec inc. — 60sec-Paiement

Pièce jointe à la demande d'enregistrement d'un fournisseur de services de paiement

Banque du Canada — Loi sur les activités associées aux paiements de détail — section 11

Demandeur : 9567-0048 Québec inc., NEQ 1182124850, 102 chemin Miltimore, Sutton (Québec) J0E 2P0

Nom commercial : 60sec-Paiement

Personne désignée : Yves Perron, président-directeur général — y@le102.ca — 514-885-9351

Cadre dirigeant responsable : Yves Perron, président-directeur général

Date prévue de lancement : 1^{er} avril 2027

Version : 1.0 — 8 septembre 2026

La présente pièce développe le plan de réponse et de rétablissement exigé à l'alinéa 5(1)i) du Règlement sur les activités associées aux paiements de détail, ainsi que les obligations de notification de l'article 18 de la Loi. Elle complète le cadre de gestion des risques opérationnels joint à la même section, sans s'y substituer : celui-là énonce ce que le demandeur prévoit, celle-ci décrit comment il l'exécute. Les termes suivis de la mention (*voir pièce 05*) y sont définis.

1. Objet et articulation avec le cadre de gestion des risques

Le Règlement exige un cadre unique, qui couvre à la fois la gestion des risques opérationnels et la réponse aux incidents. Le demandeur le présente en deux pièces parce qu'elles ne servent pas au même moment : l'une se lit avant, l'autre se lit pendant.

Pièce	Ce qu'elle établit	Quand elle sert
Pièce 05 — cadre de gestion des risques opérationnels et de réponse aux incidents	Les objectifs, les risques recensés, les mesures de protection, les capacités de détection, les principes du plan de réponse, les examens et les mises à l'essai.	À froid : conception, examen annuel, essais, approbation.
Pièce 06 — le présent document	L'échelle de gravité, les rôles pendant un incident, les procédures par type d'incident, les gabarits d'avis et de dossier, la revue postérieure.	À chaud : dès qu'un signal franchit un seuil, et jusqu'à la clôture du dossier.

Aucune règle nouvelle n'est introduite ici. Les seuils de détection, les délais de qualification et de notification, la qualification des répercussions importantes et les mesures immédiates sont ceux de la pièce 05. La présente pièce les rend exécutables : qui fait quoi, dans quel ordre, avec quels mots. En cas de divergence entre les deux documents, la pièce 05 prévaut, et la présente pièce est corrigée.

2. L'échelle de gravité

La gravité commande la **mobilisation** : combien de personnes sont réveillées et à quelle vitesse. Elle ne commande pas la notification, qui dépend d'une qualification distincte — celle des répercussions importantes au sens de l'article 18. Les deux décisions se prennent séparément, même si elles se rejoignent souvent.

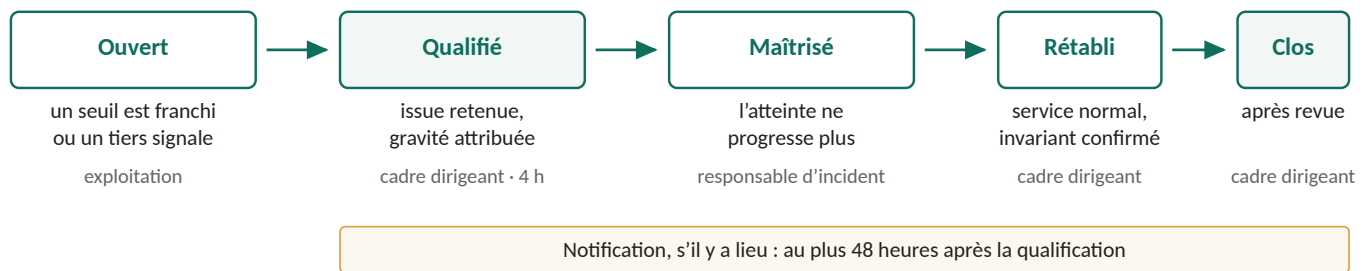
Niveau	Situation	Mobilisation	Premier geste
G1 critique	Des fonds d'utilisateurs finaux sont en cause : écart de rapprochement, invariant du grand livre en échec, soupçon de paiement non autorisé, atteinte au compte en fiducie.	Immédiate, à toute heure. Cadre dirigeant joint sans délai.	Suspension des transmissions.
G2 majeur	Le service est interrompu ou une donnée confidentielle est en cause, sans qu'un mouvement de fonds soit erroné : indisponibilité prolongée, compromission d'un accès, incident chez un tiers.	Immédiate en heures ouvrables, sans délai hors heures si un lot est en attente.	Isolement de l'accès ou du composant en cause.
G3 modéré	Une opération ou un lot est retardé ou refusé sans perte : fichier rejeté à l'entrée, lot manqué, refus d'un virement.	Heures ouvrables, par l'exploitation.	Correction et redépôt, ou report documenté.

Niveau	Situation	Mobilisation	Premier geste
G4 mineur	Anomalie sans effet sur une opération ni sur une donnée : alerte isolée, dégradation passagère, avis de sécurité sans exposition.	Traitement courant.	Consignation et suivi.

La gravité est attribuée à l'ouverture, sur la foi de ce qui est connu, et révisée aussi souvent que nécessaire. Elle ne se révisé jamais à la baisse pour la seule raison que la réponse progresse : un incident G1 maîtrisé demeure un incident G1 dans le dossier.

Gravité et répercussions importantes ne se confondent pas. Un incident G3 — un lot manqué la veille d'une échéance de paie — peut avoir des répercussions importantes pour les personnes touchées et exiger une notification, tandis qu'un incident G2 contenu en quelques minutes peut n'en avoir aucune. La gravité mesure ce qu'il faut mobiliser ; la qualification mesure ce qu'il faut déclarer. Le cadre dirigeant prononce la seconde dans les quatre heures suivant la détection, selon la pièce 05.

3. Le cycle de vie d'un incident



Le passage de « maîtrisé » à « rétabli » est celui que l'on confond le plus. Un incident est **maîtrisé** lorsque l'atteinte ne progresse plus : la clé est révoquée, les transmissions sont suspendues, le lot est arrêté. La cause n'est pas nécessairement connue et le service n'est pas nécessairement revenu. Il est **rétabli** lorsque le service fonctionne de nouveau, que l'invariant du grand livre est confirmé et que le rapprochement du jour ne présente aucun écart. Entre les deux, le demandeur ne reprend pas les transmissions au motif que la situation « semble stable ».

Passage	Condition	Qui le prononce
Vers ouvert	Un seuil de la section 7 de la pièce 05 est franchi, ou un tiers signale un incident. Le doute suffit : un incident ouvert à tort se referme sans conséquence.	Toute personne de l'exploitation
Vers qualifié	L'issue est retenue parmi les trois de la pièce 05, et la gravité est attribuée. Au plus quatre heures après la détection, au besoin sur l'hypothèse la plus défavorable.	Cadre dirigeant
Vers maîtrisé	Aucune aggravation n'est plus possible par le mécanisme en cause.	Responsable d'incident

Passage	Condition	Qui le prononce
Vers rétabli	Service normal, invariant du grand livre confirmé, rapprochement sans écart, lots en attente traités ou reportés en connaissance de cause.	Cadre dirigeant
Vers clos	Cause première établie, mesures correctives décidées et confiées à un responsable, dossier complet, avis de suivi émis s'il y a lieu.	Cadre dirigeant, après la revue

4. Les rôles pendant un incident

Les rôles ci-dessous sont des fonctions, non des postes : une même personne peut en tenir plusieurs, à une exception près, énoncée dans l'encadré.

Rôle	Ce qu'il fait pendant l'incident
Responsable d'incident	Conduit la réponse : tient la chronologie, décide des mesures immédiates, répartit les tâches, prononce la maîtrise. Il est désigné à l'ouverture et son nom figure au dossier. Il ne conduit pas l'enquête technique lui-même s'il peut l'éviter.
Cadre dirigeant	Qualifie l'incident, autorise et signe les notifications, décide du rétablissement et de la clôture, engage les dépenses nécessaires.
Exploitation	Ouvre le dossier, applique les mesures sur la plateforme — suspension, gel, révocation —, exécute le rapprochement et le rejeu des lots.
Ingénierie	Établit la cause première, propose le correctif ou la mesure d'atténuation, procède à la remise en service.
Communication	Rédige les avis aux abonnés et aux tiers à partir des gabarits de l'annexe A, et tient le registre de ce qui a été dit, à qui et quand.
Agent de conformité	Est informé de tout incident G1 ou G2 et de tout incident mettant en cause un abonné ; détermine si une déclaration relevant du programme de conformité est requise, indépendamment de la notification prévue à l'article 18.

La seule séparation qui ne se cumule pas. La personne qui conduit la réponse ne prononce pas la qualification : c'est le cadre dirigeant qui la prononce. La raison est simple et vaut d'être dite — celui qui est au milieu de l'action a intérêt, sans même s'en rendre compte, à croire que la situation est moins grave qu'elle ne l'est. Lorsque le cadre dirigeant est lui-même responsable d'incident, il consigne au dossier les faits sur lesquels il fonde sa qualification, de manière que la ressource indépendante prévue à l'article 10 du Règlement puisse la réexaminer.

Joignabilité

- Les coordonnées du cadre dirigeant, de la suppléance, de l'institution financière parraine, du partenaire de virement et de l'hébergeur sont tenues **hors ligne** et à jour, de sorte qu'une panne des systèmes n'empêche pas de les atteindre.
- Une suppléance nommée existe pour chaque rôle. Un incident ne s'arrête pas parce qu'une personne est en congé.
- Les incidents G1 et G2 se traitent à toute heure ; les incidents G3 et G4, en heures ouvrables, sauf lorsqu'un lot est en attente de transmission le jour même.

5. Les procédures par type d'incident

Chaque procédure suit la même structure : les premiers gestes, la qualification, la communication, puis la sortie. Elles ne remplacent pas le jugement du responsable d'incident ; elles lui évitent d'avoir à l'exercer sur les points déjà tranchés.

5.1 Écart de rapprochement ou invariant du grand livre en échec

Gravité G1. Signaux : section 7 de la pièce 05.

1. **Suspendre les transmissions.** Aucun lot ne part tant que l'écart n'est pas expliqué. Les instructions continuent d'être acceptées et demeurent en attente.
2. **Figurer l'état.** Extraire et conserver l'état du grand livre, le relevé de l'institution parraine et les journaux du jour, avant toute tentative de correction.
3. **Mesurer.** Établir le montant de l'écart, son sens, et les abonnés dont le solde est touché. Un écart d'un cent se traite comme un écart de mille dollars : c'est la cause qui importe, non le montant.
4. **Qualifier** dans les quatre heures. Une atteinte à l'intégrité du grand livre a des répercussions importantes dès qu'un solde d'abonné ou un paiement en est affecté.
5. **Corriger par contre-passation seulement.** Aucune écriture n'est modifiée ni effacée ; l'écriture d'origine demeure visible.
6. **Rétablir** lorsque l'invariant est confirmé et que le rapprochement du jour ne présente plus d'écart. Reprendre alors les transmissions, en vérifiant les dates de règlement portées aux lots en attente.

5.2 Fichier rejeté à l'entrée ou lot manqué

Gravité G3, ou G2 si une échéance de paie ou de remise est en cause.

1. **Établir la cause du rejet** auprès de l'institution parraine : format, longueur d'enregistrement, totaux de l'enregistrement Z, en-tête.
2. **Corriger et redéposer** si l'heure de tombée le permet encore. Sinon, reporter au jour ouvrable suivant et le consigner.
3. **Prévenir les abonnés touchés** dès que le report est acquis, sans attendre le dépôt effectif, en indiquant la nouvelle date de règlement.
4. **Qualifier.** Un lot manqué a des répercussions importantes lorsqu'il retarde une paie, une remise gouvernementale ou tout paiement à échéance légale.
5. **Vérifier l'absence de double dépôt** avant le redépôt : le numéro de création de fichier doit être unique.

5.3 Compromission d'un accès, d'une clé ou d'un compte

Gravité G2, ou G1 si une opération a pu être initiée.

1. **Révoquer** la clé, le jeton ou le compte en cause, immédiatement et sans attendre la confirmation de l'hypothèse.
2. **Rechercher les opérations initiées** par cet accès depuis la dernière utilisation légitime connue, et arrêter les lots qui les portent s'ils ne sont pas transmis.
3. **Déterminer ce qui a été consulté**, à partir des journaux d'accès, et non ce qui aurait pu l'être.
4. **Qualifier.** Un accès non autorisé a des répercussions importantes lorsqu'il en résulte un risque réel de préjudice grave, ou qu'un tel risque est créé.

5. **Aviser l'abonné** dont les données ou les clés sont en cause, même si l'origine se trouve chez lui.
6. **Rétablir** après réémission des accès et vérification qu'aucune opération non autorisée n'a été transmise.

5.4 Indisponibilité d'un tiers

Gravité G2. Tiers visés : hébergeur, institution parraine, partenaire de virement, fournisseur de vérification.

1. **Constater et joindre** le tiers par le canal convenu à l'entente, en notant l'heure du premier contact.
2. **Appliquer la procédure de dégradation** propre au tiers : report du lot, bascule du virement Interac vers le rail par lots, report de l'activation d'un abonné lorsque la vérification d'entreprise est indisponible.
3. **Estimer la durée** et la comparer à l'heure de tombée du jour.
4. **Prévenir les abonnés** si le service est interrompu au-delà d'une heure ouvrable, ou si un lot est reporté.
5. **Qualifier** : l'incident du tiers peut être aussi un incident du demandeur, notamment si des données lui ont échappé.

5.5 Vague de retours ou abonné suspect

Gravité G2. Signal : taux de retour au-delà du seuil porté à la fiche de l'abonné.

1. **Abaisser le plafond** de l'abonné et, au besoin, suspendre ses encaissements pendant l'examen.
2. **Exercer le droit d'audit** sur les ententes de débit préautorisé détenues par l'abonné.
3. **Distinguer les trois causes possibles** — clientèle qui se détériore, processus négligent, prélèvement sans droit — avant de décider de la suite.
4. **Informé l'agent de conformité** dans tous les cas, et l'institution parraine lorsque le taux agrégé de la plateforme s'en trouve affecté.
5. **Décider** : révision des limites et de la réserve, plan de correction imposé à l'abonné, ou résiliation.

5.6 Incident signalé par un tiers

Gravité selon l'exposition. Il ne s'agit pas d'un avis de vulnérabilité, qui suit la gestion des correctifs.

1. **Ouvrir un dossier au nom du demandeur** : l'incident d'un tiers qui touche ses données ou son service est son incident.
2. **Établir l'exposition** : quelles données, quels abonnés, quelle période.
3. **Qualifier** sans attendre que le tiers ait terminé son propre examen. Le délai de l'article 18 court à partir de la détermination du demandeur, non de celle du tiers.
4. **Documenter ce que le tiers a communiqué**, à quelle heure, et ce qu'il n'a pas communiqué.

6. La communication

Destinataire	Déclencheur	Contenu
Banque du Canada	Qualification de répercussions importantes	Les éléments exigés à la section 9 de la pièce 05, transmis au plus tard 48 heures après la qualification, puis les avis de suivi requis.
Utilisateurs finaux touchés	Idem, ou interruption de service au-delà d'une heure ouvrable	Nature de l'incident, dates de début, de détection et de résolution, répercussions propres au destinataire, mesures correctives recommandées.
Institution parraine	Tout incident G1, tout rejet de fichier, toute suspension des transmissions	Ce qui touche les fichiers, le compte en fiducie ou le calendrier de dépôt. Elle est avisée en vertu de l'entente, sans attendre la qualification.
Autres fournisseurs et chambres de compensation touchés	Qualification de répercussions importantes	Selon la section 9 de la pièce 05.
Abonnés non touchés	Interruption générale du service	Un état de service factuel, sans détail technique exploitable.

Trois règles de rédaction. Ne rien affirmer qui ne soit établi : « nous établissons actuellement si des données ont été consultées » est préférable à « aucune donnée n'a été consultée » tant que les journaux n'ont pas été examinés. Donner une prochaine échéance plutôt qu'une promesse de résultat. Et ne jamais laisser un abonné apprendre d'un tiers un incident qui le concerne.

7. Après l'incident

- **Revue postérieure** — tout incident G1 ou G2 donne lieu à une revue dans les dix jours ouvrables suivant le rétablissement. Elle porte sur la chronologie, la cause première, ce qui a permis de détecter, ce qui a retardé la réponse, et ce qui aurait empêché l'incident.
- **Mesures correctives** — chacune est confiée à une personne nommée, avec une échéance. Le dossier ne se clôt pas tant qu'elles ne sont pas décidées, même si leur exécution s'étale ensuite.
- **Effet sur le cadre** — un incident qui révèle une lacune du cadre de gestion des risques déclenche une modification de celui-ci, et donc une nouvelle approbation, sans attendre l'examen annuel.
- **Effet sur les essais** — un scénario d'incident survenu réellement est ajouté aux essais fondés sur des scénarios prévus à la section 11 de la pièce 05.
- **Sans recherche de faute** — la revue établit des causes, non des responsabilités individuelles. Un cadre qui punit la déclaration obtient moins de déclarations, non moins d'incidents.

Annexe A — Gabarits d’avis

Avis à la Banque du Canada

Demandeur : 9567-0048 Québec inc. — 60sec-Paiement — numéro d’enregistrement

Personne-ressource : nom, fonction, courriel, téléphone joignable

Numéro d’incident : INC-AAAA-NNN

Chronologie : début — détection — détermination des répercussions importantes — résolution, s’il y a lieu

Mode de détection : contrôle continu, avis d’un tiers, signalement d’un abonné

Description sommaire : ce qui s’est produit, en termes factuels

Activités de paiement touchées : encaissement, décaissement, virement Interac, détention de fonds

Ampleur : nombre d’utilisateurs finaux touchés, nombre d’opérations, valeur en cause

Mesures de réponse prises : mesures immédiates, atténuation, rétablissement

Cause première : établie, ou état de l’enquête et prochaine échéance

Avis à un utilisateur final touché

Objet : incident touchant votre compte 60sec-Paiement — INC-AAAA-NNN

Ce qui s’est produit : une phrase factuelle, sans jargon ni détail technique exploitable

Quand : date et heure du début, de la détection et, s’il y a lieu, de la résolution

Ce que cela signifie pour vous : opérations, solde ou données précisément en cause

Ce que nous avons fait : mesures prises et état actuel

Ce que nous vous recommandons de faire : mesures correctives à sa portée, s’il y en a

Prochaine communication : date à laquelle il aura de nos nouvelles, même sans élément nouveau

Pour nous joindre : canal direct, sans passer par le soutien courant

Annexe B — Le dossier d’incident

Un dossier est ouvert pour chaque incident, quel que soit son niveau de gravité, et conservé sept ans au Canada. Il porte au minimum :

Rubrique	Contenu
Identification	Numéro, date d’ouverture, responsable d’incident désigné, gravité initiale et gravité finale.
Chronologie	Heures de survenance, de détection, de qualification, de maîtrise, de rétablissement et de clôture, avec la source de chaque horodatage.

Rubrique	Contenu
Qualification	Issue retenue, faits sur lesquels elle se fonde, auteur de la décision, et toute révision ultérieure.
Répercussions	Utilisateurs finaux, opérations et valeurs en cause ; données consultées ou communiquées, le cas échéant.
Mesures	Mesures immédiates, atténuation, correction, rétablissement — chacune horodatée et attribuée.
Communications	Chaque avis émis : destinataire, heure, contenu, et accusé de réception s'il y a lieu.
Cause première	Analyse et conclusion, ou motif pour lequel la cause n'a pu être établie.
Suites	Mesures correctives, responsables, échéances, et état d'avancement jusqu'à leur exécution.

Documents liés. Cadre de gestion des risques opérationnels : pièce 05. Description des services et des processus de paiement : question 6.1. Diagrammes des processus de paiement : question 6.3. Contrats avec les tiers et procédure de supervision : section 13. Programme de conformité : section 16.

Notes de rédaction — à retirer avant le dépôt

Point	À faire
Deux pièces ou une	Le Règlement exige un cadre unique. Confirmer que la Banque accepte une présentation en deux pièces, ou fusionner la présente pièce en annexe de la pièce 05 avant le dépôt.
Échelle de gravité	Les quatre niveaux et leurs seuils de mobilisation sont proposés. Les arrêter, et vérifier qu'ils s'accordent avec les engagements de service pris au contrat d'abonnement.
Responsable d'incident	Le rôle suppose une personne autre que le cadre dirigeant pour être pleinement effectif. Le nommer en même temps que la seconde personne habilitée à approuver les lots.
Joignabilité	Constituer la fiche hors ligne des coordonnées et convenir avec chaque tiers du canal d'urgence et de son délai de réponse ; le reporter aux ententes de la section 13.
Gabarits d'avis	Confronter le gabarit destiné à la Banque au formulaire réel du portail au moment du dépôt, et faire relire le gabarit destiné aux utilisateurs finaux par le conseiller juridique.
Délai de revue	Les dix jours ouvrables sont une proposition ; l'arrêter et l'inscrire au calendrier de la section 12 de la pièce 05.